códigofacilito

Bootcamp · Módulo 4: Integración App + DB

Autenticación y RLS

Clase 2 de 6 · Supabase + Next.js



Rodrigo Méndez
rodrigomendez.dev

códigofacilito

📋 Tabla de contenido

/01 El problema y la meta

/02 Autenticación

/03 Autorización con RLS

/04 Roles en la app

/05 Para cerrar la clase



códigofacilito

/01

El problema y la meta

Qué vamos a construir hoy, y por qué.



códigofacilito

EL PROBLEMA

Todos los pedidos viven en la misma tabla. ¿Cómo hace la base para que cada cliente vea solo los suyos?

HOY: CUALQUIERA VE TODO

pedidos	
Pedido 1	de Ana
Pedido 2	de Beto
Pedido 3	de Ana
Pedido 4	de Beto

Beto puede leer los pedidos de Ana

LA SOLUCIÓN: LA BASE FILTRA CADA CONSULTA

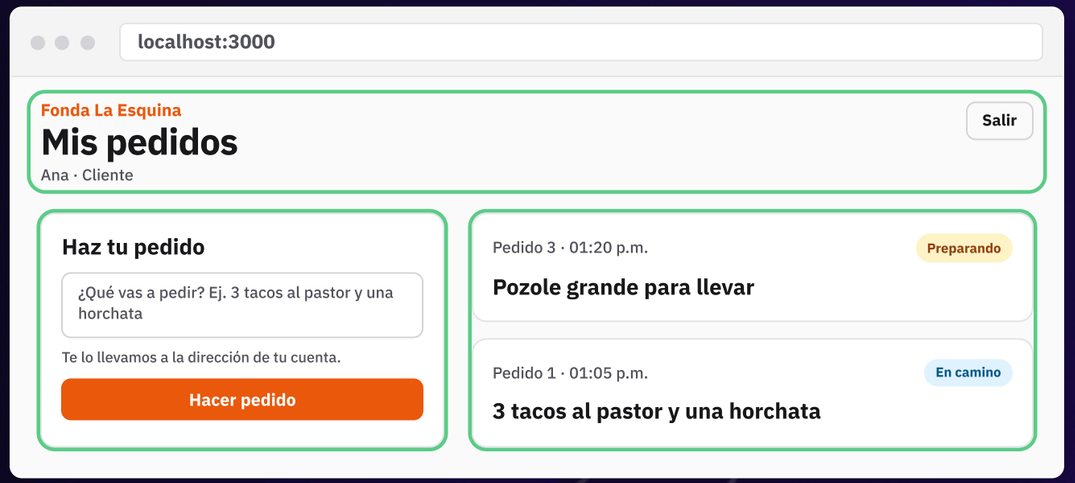
Ana	Pedido 1 · Pedido 3
Beto	Pedido 2 · Pedido 4
La tienda	todos
Sin sesión	ninguno

Una sola tabla: cada quien ve solo lo suyo

códigofacilito

LA META DE HOY

Cada quien entra con su cuenta y ve lo suyo



1. **Entras con tu cuenta**
   Registro e inicio de sesión con correo y contraseña.
2. **Pides sin repetir tus datos**
   La dirección y el teléfono salen de tu perfil.
3. **Solo ves tus pedidos**
   La tienda entra con su cuenta y ve todos.

RASTRO, SIGUE TU PEDIDO · UNA SOLA APP QUE CRECE CLASE A CLASE

CLASE 1	CLASE 2	CLASE 3	CLASE 4	CLASE 5	CLASE 6
Base de datos	Auth y RLS	Realtime	Edge Functions	Storage	Eventos y Broadcast
	Hoy				

códigofacilito

/02 Autenticación

Quién eres: la cuenta, la sesión y el perfil.



códigofacilito

DOS PREGUNTAS DISTINTAS

Autenticación y autorización

AUTENTICACIÓN · SUPABASE AUTH

¿Quién eres?

Registro e inicio de sesión con correo y contraseña. El resultado es una sesión: un token que dice quién eres.

AUTORIZACIÓN · RLS

¿Qué puedes hacer?

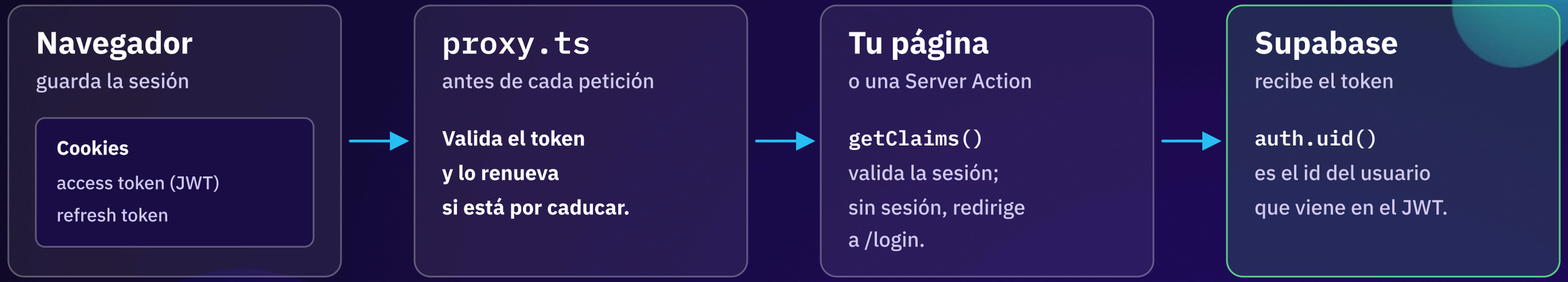
Políticas en la base de datos: qué filas puede leer y escribir cada usuario.

> Primero la base sabe quién eres; con eso decide qué te deja ver y cambiar. Hoy hacemos las dos.

códigofacilito

LA SESIÓN

La sesión viaja en cookies



Una página no puede escribir cookies: por eso la renovación vive en proxy.ts.

códigofacilito

EL REGISTRO

Al registrarte, la base crea tu perfil



El perfil tiene RLS desde que nace: cada usuario solo puede leer el suyo.

> El pedido ya no pide dirección ni teléfono: los toma del perfil de quien tiene la sesión.

códigofacilito

/03

Autorización con RLS

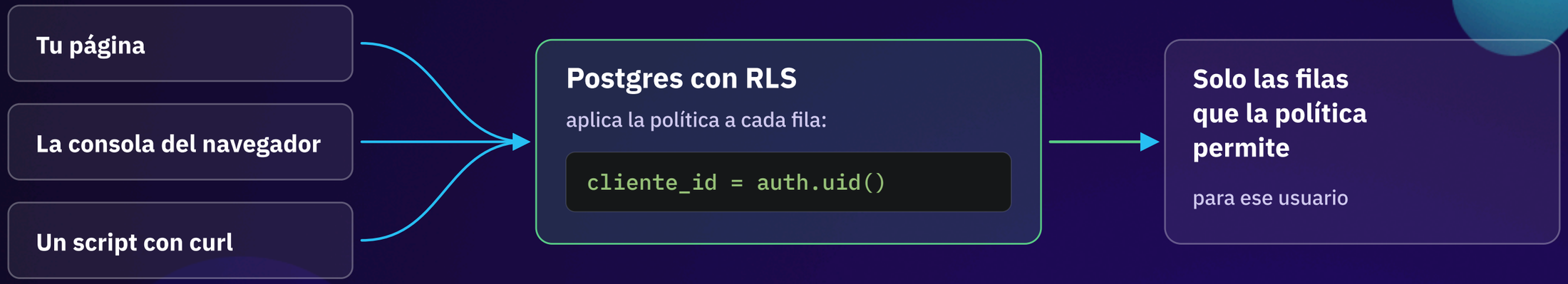
Qué filas puede leer y escribir cada usuario.



códigofacilito

ROW LEVEL SECURITY

La base filtra cada consulta



- Se activa por tabla
- Sin políticas, nadie ve nada
- Aplica venga de donde venga la consulta
- La llave secreta se la salta

códigofacilito

LAS POLÍTICAS DE PEDIDOS

Primero en español, luego en SQL

pedidos · RLS

La regla	Operación	La condición
El cliente ve sus pedidos y la tienda ve todos	select · using	`cliente_id = auth.uid() or es_tienda()`
El cliente hace pedidos a su nombre	insert · with check	`cliente_id = auth.uid()`
Solo la tienda cambia el estado	update · using	`es_tienda()`

- **using** filtra qué filas puedes leer o modificar
- **with check** valida las filas que escribes
- `cliente_id` se llena solo: `default auth.uid()`

códigofacilito

EL ERROR DEL DÍA

Activas RLS y la lista sale vacía

1

Activas RLS

En la tabla de pedidos, todavía sin políticas.

2

Lista vacía

Ni la tienda ve nada: sin políticas, RLS niega todo.

3

Sin error

La consulta responde bien, con cero filas.

4

Las políticas

Cada una abre un tipo de acceso.

> Si una lista sale vacía de repente y no hay error, revisa si la tabla tiene RLS y qué políticas tiene.

códigofacilito

/04 Roles en la app

La tienda y los clientes, en la misma app.



códigofacilito

LA CUENTA DE LA TIENDA

La tienda no se registra en la app

REGISTRO EN LA APP

Solo clientes

Cualquiera puede crear una cuenta, y todas nacen con rol cliente.

LA TIENDA

Una migración en SQL

Crea su cuenta directo en la base y cambia su perfil a rol tienda.

`es_tienda()` Función de la base que responde si la sesión es de la tienda. Es **security definer**: puede leer todos los perfiles, pero solo contesta sí o no.

códigofacilito

LA PÁGINA SEGÚN QUIÉN ENTRA

Esconder un botón no es seguridad

LA PÁGINA · INTERFAZ

Enseña lo que te toca

El cliente ve el formulario "Haz tu pedido"; la tienda, los botones de estado. Lo decide leyendo el rol del perfil.

LA BASE · SEGURIDAD

Decide lo que puedes hacer

Si un cliente manda el update a mano, la política de update lo deja en cero filas y no cambia nada.

> La interfaz se adapta al rol; la regla vive en la base.

códigofacilito

/05

Para cerrar la clase

Lo que te llevas, la tarea y lo que sigue.



códigofacilito

LO QUE TE LLEVAS HOY

Tres ideas

1

Autenticación no es autorización

Supabase Auth dice quién eres; las políticas RLS, qué puedes hacer.

2

La sesión viaja en cookies

`proxy.ts` la renueva y cada página decide si te deja pasar.

3

RLS filtra en la base

Aplica venga de donde venga la consulta. Sin políticas, nadie ve nada.

códigofacilito

TAREA · PARA LA CLASE 3

Construye tú solo lo que viste hoy

CÓMO SÉ QUE YA QUEDÓ

- [ ] Te registras, entras y sales con correo y contraseña.
- [ ] Sin sesión, la página de pedidos te manda a entrar.
- [ ] Cada cliente ve solo sus pedidos; la tienda ve todos y solo ella cambia estados.
- [ ] La consulta de la consola con la llave publishable regresa vacío.

¿NO TE SALIÓ?

No pasa nada

Toma la base de la clase 3: ya trae todo esto hecho. Compárala con lo tuyo y encuentra qué te faltó.

Recursos para profundizar

- Supabase Auth en Next.js, del lado del servidor: supabase.com/docs/guides/auth/server-side/creating-a-client
- Row Level Security: supabase.com/docs/guides/database/postgres/row-level-security
- Datos de usuario y perfiles: supabase.com/docs/guides/auth/managing-user-data
- `proxy.ts` en Next.js: nextjs.org/docs/app/api-reference/file-conventions/proxy



códigofacilito

UNA ÚLTIMA COSA

Tu tabla ya no está expuesta



Hoy la tienda recarga para ver pedidos nuevos.
En la clase 3 la pantalla se actualiza sola.